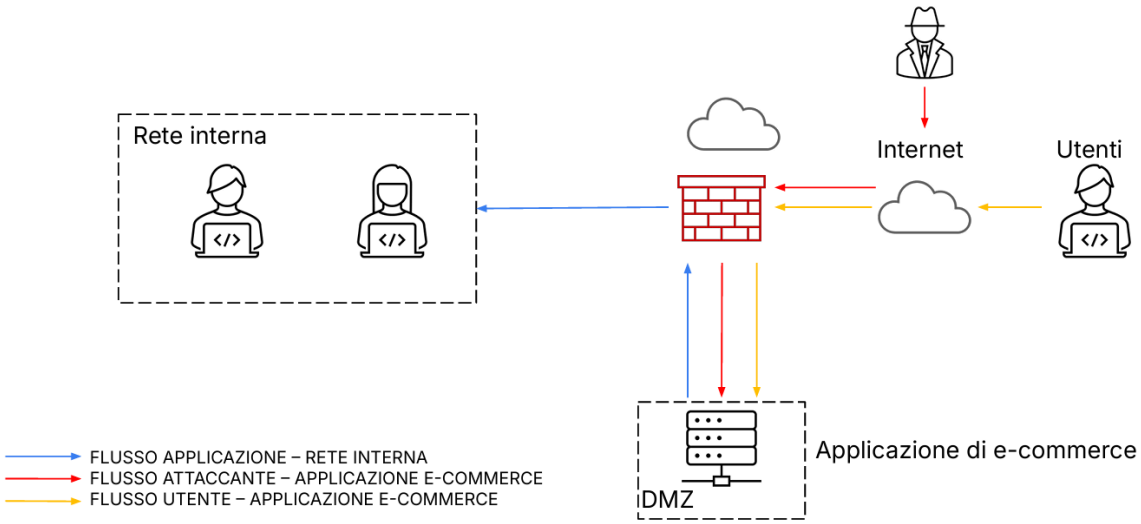
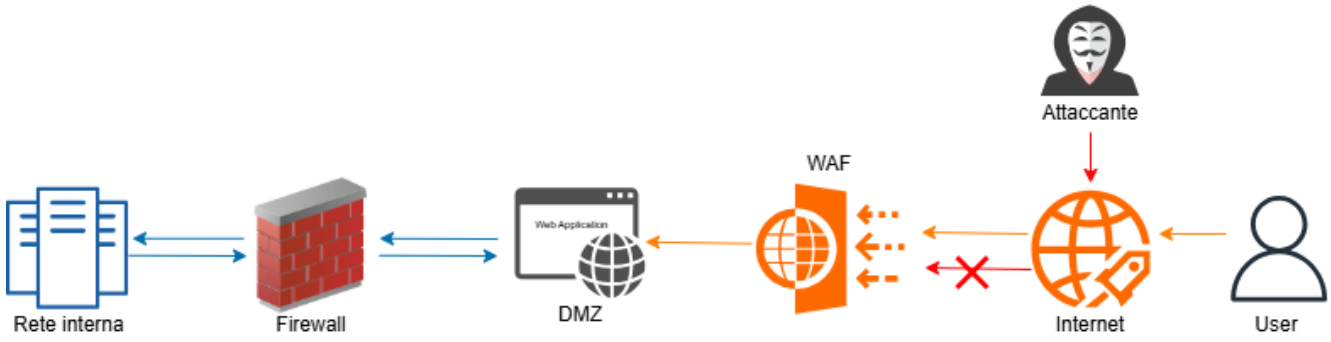
Report Tecnico: Hardening Infrastrutturale

Il presente report si focalizzerà sull'implementazione di misure di Hardening per prevenire attacchi applicativi (SQLi/XSS), sulla valutazione dell'impatto economico di attacchi Denial of Service e sulla definizione di una strategia per il contenimento di malware, garantendo l'integrità dei dati presenti nella rete interna. L'infrastruttura di partenza è la seguente:



1. Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato?

Implementazione WAF (Web Application Firewall): posizionato tra Internet e la WebApp.
Un WAF analizza il traffico HTTPS e blocca payload sospetti tipici di SQLi e XSS.



Gestione del traffico:
- Internet (User/Attacker): Invia una richiesta HTTP.
- WAF: La richiesta arriva al WAF. Qui viene fatta la Validation. Se contiene payload SQLi o script XSS, il WAF la blocca lì.
- Web Application (DMZ): Se la richiesta è pulita, il WAF la inoltra all'applicazione.
- Firewall: Regola il traffico tra la DMZ e la Rete Interna.
- Rete Interna: Riceve solo connessioni autorizzate e filtrate provenienti dall'applicazione (mai direttamente da Internet o dal WAF).

2. L’applicazione Web subisce un attacco di tipo DDoS dall’esterno che rende l’applicazione non raggiungibile per 10 minuti. Normalmente, in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce.

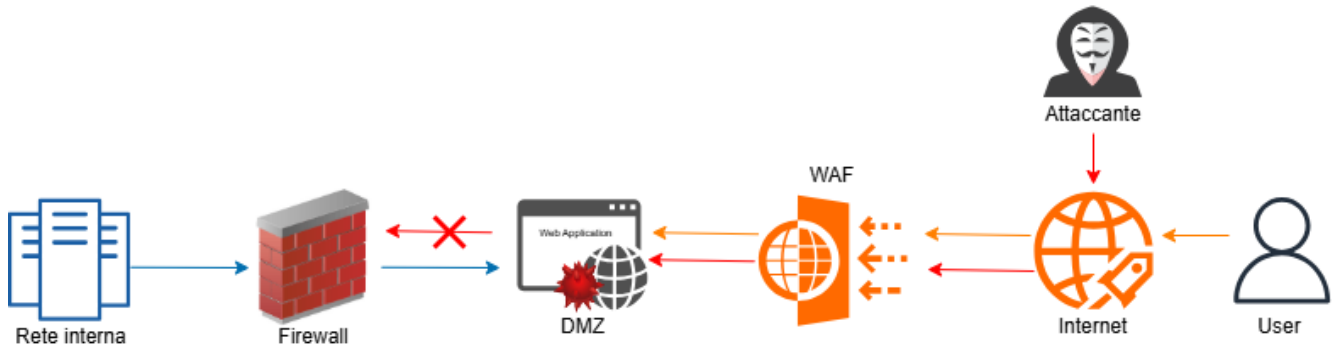
Calcolo del Danno Economico:
- Durata downtime: 10 minuti
- Perdita per minuto: 1.500 €
- **Impatto Totale:** 10 min x 1.500 € / min = 15.000 €

Azione preventiva: Configurazione sul WAF per limitare il numero di richieste per singolo IP in un determinato intervallo di tempo.

Load Balancer: Distribuire il traffico su più istanze dell'applicazione in zone geografiche diverse per mitigare il DDoS a livello di infrastruttura.

3. L’applicazione Web viene infettata da un malware. La priorità è che il malware non si propaghi sulla rete interna.

Metodo di contenimento Malware:
- Blocco flusso DMZ --> INT NET
Configurare il Firewall per applicare una regola di filtraggio totale del traffico dalla DMZ verso la Rete Interna. In questo modo anche se il malware è attivo e l'attaccante ha ancora accesso ogni pacchetto inviato dal server infetto verso la rete interna viene bloccato.

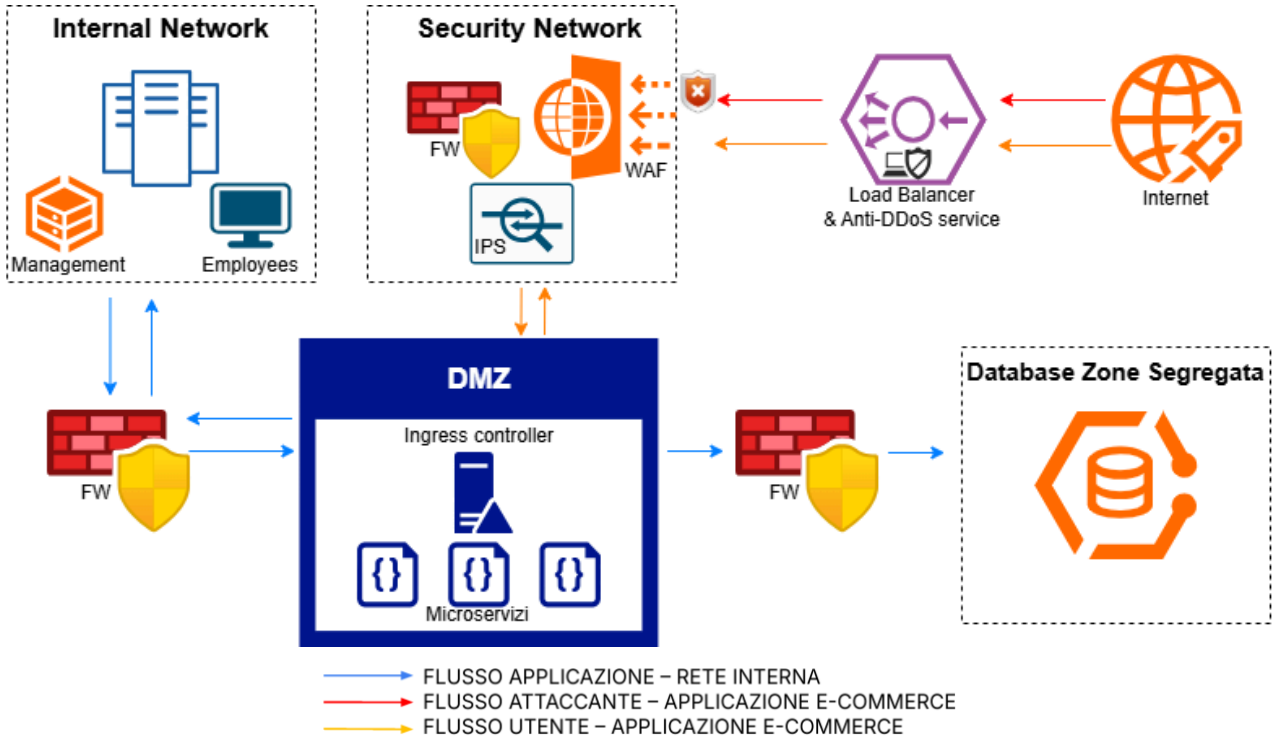


Soluzione completa:
- Isolamento DMZ
Se la rete interna ha bisogno di dati dalla Web Application, sarà un server interno a "chiamare" la DMZ. Il Firewall deve bloccare qualsiasi sessione originata dalla DMZ. In questo modo il malware non può fare scansioni di rete o movimento laterale perché non può iniziare nessuna connessione.

Lo schema High Level Design (HLD) apparirà allo stesso modo dell'immagine sopra, con la differenza che all'interno della rete aziendale sarà presente un server allocato per la comunicazione con la Web Application in isolamento.

Modifica Aggressiva HLD

Di seguito si esporrà lo schema HLD definitivo per l'azienda e-commerce, lo scopo è la progettazione di una infrastruttura immune agli attacchi spiegati precedentemente.
Oltre all'utilizzo di dispositivi di sicurezza si ha implementato la segmentazione della rete aziendale in varie VLAN:



1. Accesso Esterno: Il punto di ingresso per tutto il traffico proveniente da Internet è il **Load Balancer,** che fa da Anti-DDoS service, distribuendo le richieste in entrata per evitare il sovraccarico dei nodi applicativi.

2. Security Network: Il traffico attraversa la **Security Network**, un'area di transito dedicata al filtraggio dei payload e al rilevamento e prevenzione malware di rete. Qui è presente un Web Application Firewall (WAF) che analizza le richieste HTTPS per bloccare attacchi come SQL Injection (SQLi) e Cross-Site Scripting (XSS). L' Intrusion Prevention System (IPS) identifica indicatori di compromissione che potrebbero indicare un attacco in atto, allo scopo di prevenirlo automaticamente. Infine il Firewall applica le prime regole di instradamento, assicurandosi che solo il traffico validato dai sistemi di ispezione possa procedere.

3. DMZ e Microservizi: Una Demilitarized Zone (DMZ) che ospita la Web Application, suddivisa in vari container. L' **Ingress Controller** riceve le richieste e le smista ai vari microservizi, ognuno dei quali è isolato. Se un container viene infettato, sarà eliminato e ricreato automaticamente da un'immagine sicura, eliminando la persistenza del malware.

4. Firewall filtraggio DB: Il Firewall posizionato tra la DMZ e la Database Zone Segregata ha delle regole estremamente restrittive che permette solo il flusso di traffico destinato alla porta specifica del DB dalle sorgenti dei microservizi o host di management.

5. Database Zone Segregata: Contiene i database, non ha accesso diretto a Internet né alla rete interna, risponde esclusivamente alle chiamate filtrate dal FW.

6. Internal Firewall: Separa la Internal Network dal resto dell'infrastruttura. Blocca ogni tentativo di connessione non autorizzato originato dalla DMZ verso l'interno per prevenire il Lateral Movement. Inoltre permette agli utenti interni di accedere alle risorse stabilite (privilegio minimo) e al reparto IT di amministrare server interni, server in DMZ, Database, ecc.

7. Internal Network: VLAN del'ufficio in cui vengono ospitati gli host corporate, ciascuno dei quali avrà diverse abilitazioni, in base al ruolo della persona, tramite regole ACL da impostare sul Internal FW. Ha molta importanza che per ogni utente sia richiesta una autenticazione MFA per poter accedere alle risorse/dispositivi. Questa network sarà sotto la gestione di un team IT che si occuperà del management della rete sottostante.

Conclusione

Dopo la realizzazione del HLD si potrebbe effettuare l' Hardening dell'infrastruttura proposta all'inizio del report, si sono raggiunti diversi obiettivi:

- Mitigazione SQLi/XSS e DDoS: Progettazione di un'area d'ispezione dedicata (WAF/IPS) e di filtraggio, garantisce una protezione contro gli attacchi applicativi e alle network.

- Contenimento di potenziali Malware: tramite il principio di **Least Privilege** e della segmentazione assicura che un'eventuale compromissione della DMZ rimanga isolata. Il malware non avrebbe più la possibilità di effettuare movimenti laterali verso la rete interna o la zona database.

- Evoluzione Cloud-Native: La suddivisione in microservizi containerizzati introduce il concetto di **Immutabilità**. La capacità di distruggere e ricreare istantaneamente nodi infetti neutralizza la persistenza degli attaccanti e garantisce un'agilità operativa superiore.